Leçons apprises : automatiser les opérations cyber avec l'IA

Retour d'expérience : ce qui a marché, ce qui a planté

HackFest 2026 · Level UP Edition

31 octobre 2026

Simon « Viper » Nolet

```
root@hacktive:~$ ./level-up --player=viper --xp=0
```

Qui suis-je



Simon « Viper » Nolet

Tests d'intrusion interne · Active Directory

- Fondateur du Beginner CTF
- Créateur de la formation Sécurité 103
- Conférence « L'IA en pratique : automatiser la cybersécurité tout en protégeant vos outils d'IA »
- Aujourd'hui : AI for Cyber Operations · apprendre à utiliser l'IA, **puis l'enseigner**

10+

années en offensive

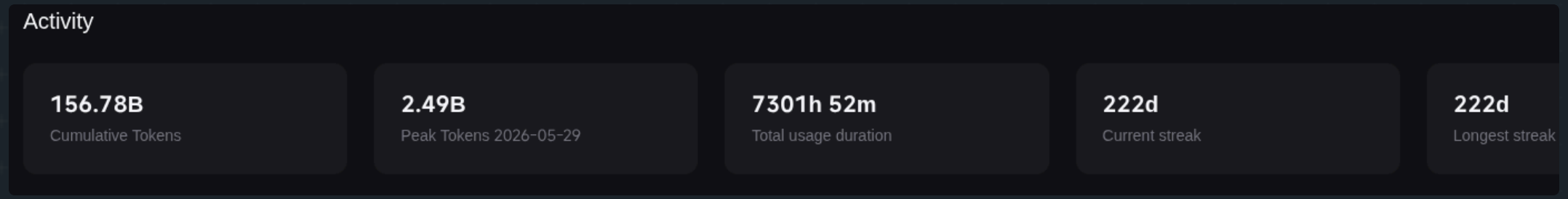
250+

tests d'intrusion

Pourquoi cette conférence?

> L'IA va toucher tous les domaines, la cyber incluse

- Apprendre comment l'utiliser · et où elle décroche, pour reprendre la relève
- Ce que j'automatise : des **tâches utiles en cyber** · veille CTI, rapport de pentest, tests d'intrusion
- Deux ans sur le terrain, souvent en me plantant · **mes erreurs en partage**



Ce que j'ai essayé avec l'IA : en cyber pis ailleurs

- **des jeux vidéo**
- **Cyber Loop**
- **hacker l'IA** : un projet qui s'y attaque
- **sécuriser l'IA** : pour en connaître les limites
- **des solveurs de CTF**
- **le tableau de reconnaissance** : pentest-brainstormer
- **le pipeline de rapport de pentest** : pentest-workflow

llmproxy

Public

Notifications Fork 0 Star 0

main 2 Branches 1 Tag

Go to file Code

ViperBlackSkull and **claude** feat: ANTHROPIC_AUTH_STYLE for Bearer-only u… d00fd84 · last week 18 Commits

.github	CI: build to /dev/null to avoid llmproxy dir/file output collision	4 months ago
demo	Add multi-agent support: Codex, Aider, OpenCode, Gemini…	6 months ago
examples	Add .env.example, examples, and tests; fix .env.example gi…	4 months ago
lib	Add MITM/TLS interception, WebSocket proxy, agent subd…	5 months ago
web	Add MITM/TLS interception, WebSocket proxy, agent subd…	5 months ago
.env.example	Add .env.example, examples, and tests; fix .env.example gi…	4 months ago
.gitignore	Add issue & PR templates; ignore goreleaser dist/	4 months ago
.goreleaser.yml	Add GoReleaser v2 config and GitHub Actions release wor…	4 months ago
CODE_OF_CONDUCT.md	Add CONTRIBUTING and CODE_OF_CONDUCT docs	4 months ago

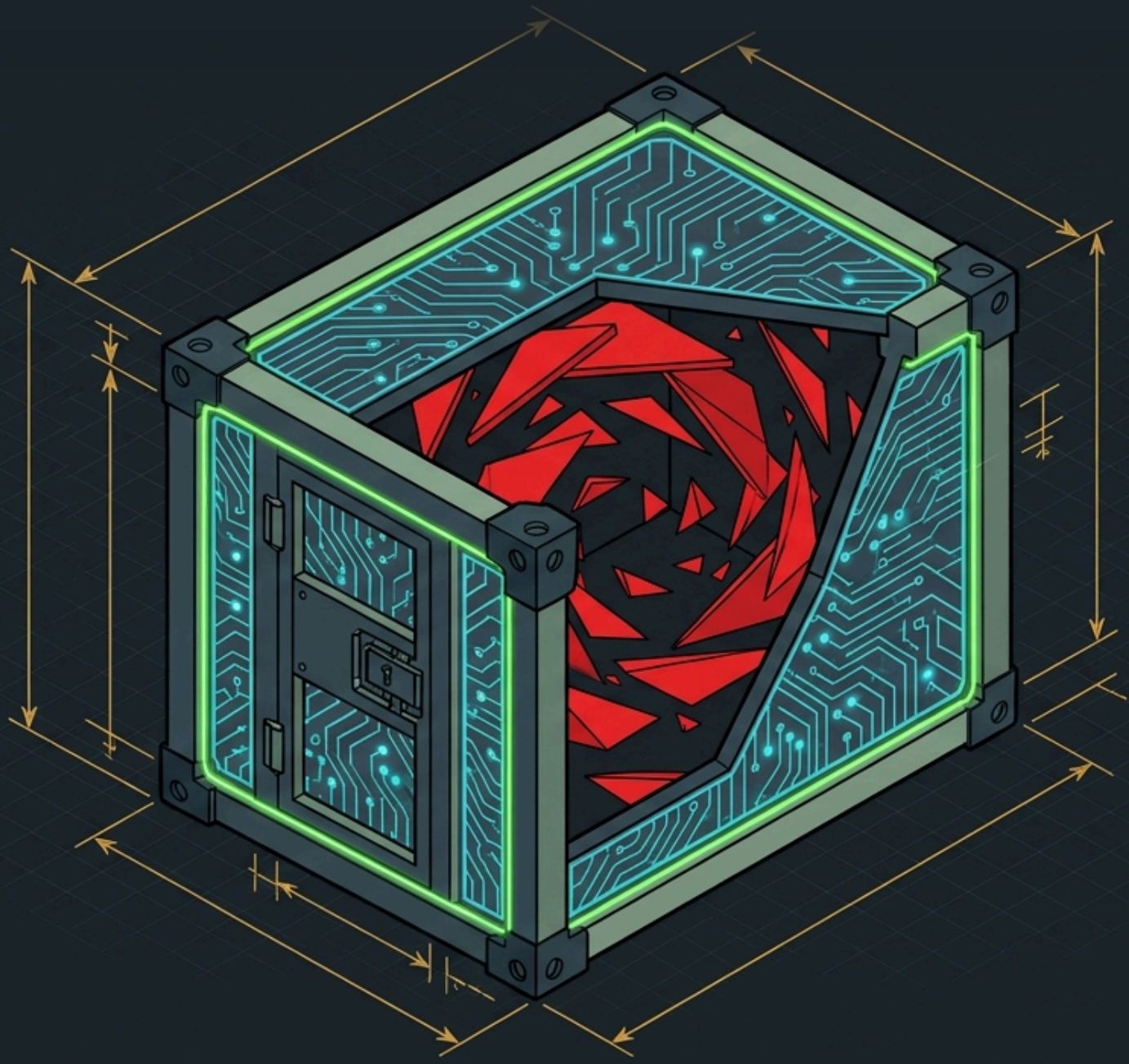
About

LLM proxy with prompt logging (proxychains style)

Readme
MIT license
Code of conduct
Contributing
Security policy
Activity
0 stars
0 watching
0 forks
Report repository

Releases 1

AgentBox



Guardian Pattern PoC

Anti-Prompt Injection Demo

Enter your message...

Send

Guardian

z.ai - Guardian

USER INPUT

DECISION

✅ Approved

REASONING

The input is a simple, benign request for a joke and contains no instructions, commands, or attempts to manipulate the system.

CONFIDENCE

NaN%

✅ APPROVED - Safe to proceed

Main Agent

z.ai - GLM

Waiting for guardian approval...

Agent processing request...

Try these examples:

- ✅ Benign: Read file
- ✅ Benign: Math question
- ⚠️ Injection: Override
- ⚠️ Injection: Role-play
- ⚠️ Injection: Probe

Apprendre avec l'IA : deux tuteurs maison

`vocabulary · trouver le mot`

- L'objectif d'abord, **une question à la fois**
- Le vocabulaire du domaine, **mot à mot**
- Il finit par rendre **la requête précise** pour tout agent

`gems · apprivoiser l'outil`

- Un outil **trouvé en ligne** : le programme va le chercher
- Puis il **tente de me l'enseigner**

Know what your tools actually do.

gemscout sends research agents through any codebase, CLI, or docs site and brings back one page: every capability ranked by value to its users — the hidden gems on top, every claim machine-verified.

latest gem

◆ Retry a failed rollout

`flag → fluxctl deploy --retry`

scout a tool

press ctrl + k to search everything

4	335	49	2
tools scouted	verified claims	evidence snapshots	contradictions caught

1

Pick any tool

a local repo, an installed CLI, a docs site — or a git URL

2

Scouts fan out

five research agents read code, docs, help output, and history —

3

One verified page

a zero-LLM script re-checks every claim; the gems surface first

← runs

opencode

repo·2.0.32 @ 367c8fb·2026-10-19·user-value mode

/home/viper/.local/state/gemscout/targets/opencode/scout-output/

publish ↗ ◆ showcase

budget pass — 543 words · 46 rendered lines

gems 5 hotkeys 8 page ledger 160 coverage

Hidden gems 5

high value × low visibility — every claim machine-verified; “try it” opens where the capability lives

Remote pairing

cli subcommand → opencode pair --remote → one-time links drive a session from browser or app via tunnel

try it ↗ docs ↗

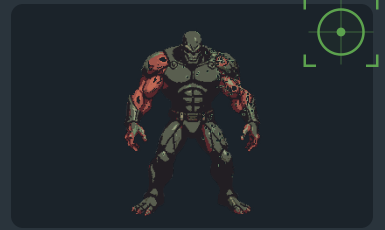
phone or browser control anywhere

buried refs ~358 touched 2026-10-17 uservalue

opencode pair 0

Account migration

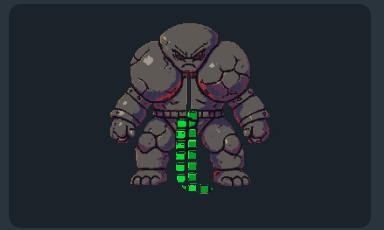
World map : cinq boss, cinq leçons



LV 1

Les hallucinations

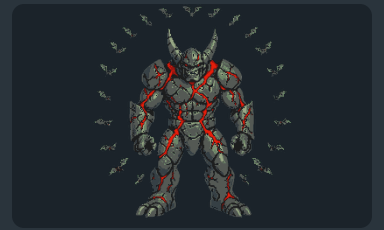
→



LV 2

Bottleneck

→



LV 3

Le chaos

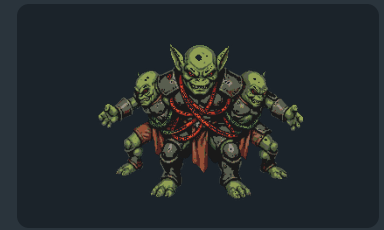
→



LV 4

L'opacité

→



LV 5

La collaboration



LV 1 · Les hallucinations

Boss № 1 : les hallucinations

BOSS 1 / 5

- Du contenu **plausible**, pas du contenu vrai
- La CVE au numéro parfait… qui n'existe pas
- Des **secrets fabriqués** : mots de passe, clés
- Relancé deux fois : **les constats changent** (même problème)
- La sévérité gonflée : **tout est critique**
- **Remède : l'agent QA**, qui teste le travail



Mon arsenal : trois armes, un boss

VIE DU BOSS



La boucle PIV

Le processus : planifier, implémenter, valider

L'agent QA

Qui : un 2e agent, jamais celui qui a écrit

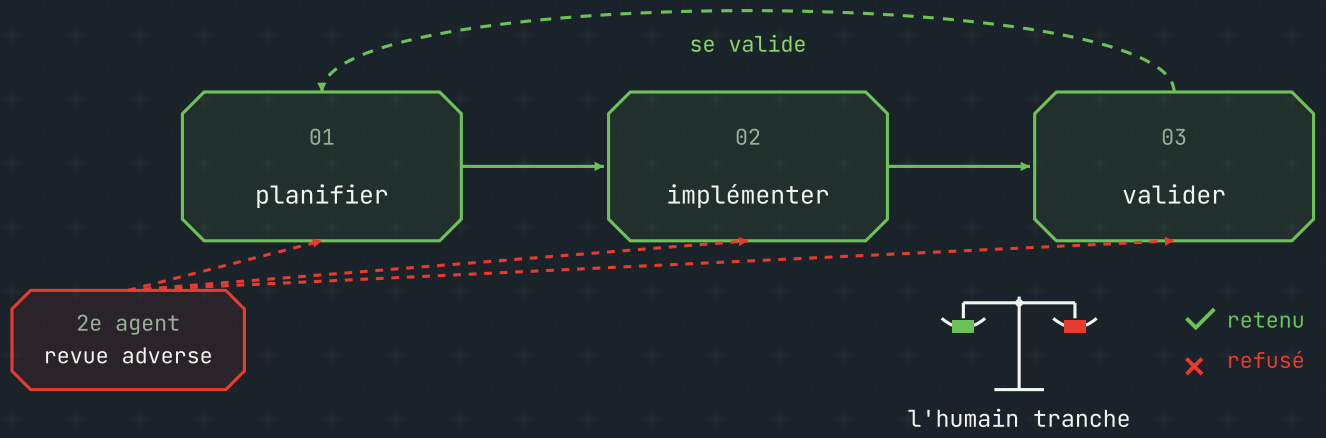
La revue adverse

Comment : le fact-check par l'attaque, comme un pentester attaque une app

La boucle PIV : le plan inclut sa validation

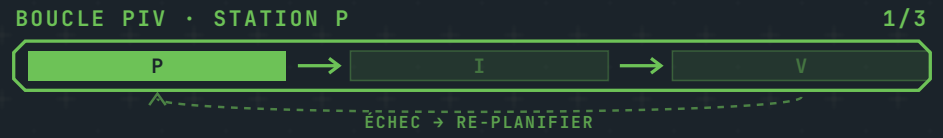
VIE DU BOSS





- Un cycle par **unité de travail** : un ticket, pas le projet entier
- Boucle publique de **Cole Medin** : le contraire du vibe coding

P · Planifier : le plan contient déjà sa preuve



> Comment saurai-je que c'est fini? Ça se décide **maintenant**

- Un document de plan : **tâche, contraintes, contexte** (code exact, versions, erreurs)
- Les **critères d'acceptation** : ce qui doit être vrai pour dire fini
- Les **tests écrits ici** rendent le verdict binaire : passé ou échoué

I · Implémenter : on délègue, on ne bricole pas



> Tout le code passe par l'agent, le plan pour **seul bagage**

- **Session neuve** : le contexte ne se traîne pas, seul le plan traverse
- Pas de retouche à la main en route : ça fausserait le verdict de la validation

V · Valider : le verdict est binaire



> « Ça roule » n'est pas une validation : chaque critère du plan se vérifie

- Échec? **On reboucle vers le plan**, la sortie ne se négocie pas
- 1-2 itérations c'est normal; à 3 et plus, **c'est le plan qui est faible**, pas le modèle
- Ma variante : **celui qui écrit ne se valide jamais**, un 2e agent teste

La boucle entière, une seule commande





- Une **description** en entrée, **un commit** en sortie : quatre skills enchaînés, des recettes enseignées à l'invocation
- La **validation** tourne à chaque étape; l'œil **indépendant**, lui, reste à part

№ 1 attaqué : l'agent QA, le test fonctionnel au navigateur

VIE DU BOSS

- **Test fonctionnel** : un navigateur, des outils, rien sur parole
- **Tous les liens cliqués** · la page charge · **JavaScript fonctionne**
- **Pas d'erreur de compilation**, pas d'erreur en console
- **La revue adverse suit** : le fact-check par l'attaque



L'adversarial review : attaquer le problème pour l'améliorer

Adversarial Arena : trois IA en rondes

Le Solveur	Le Briseur	Le Synthétiseur
Propose, compromis assumés	Failles avec scénario d'échec	Fusionne ce qui survit

SOLVER BREAKER **ADVERSARIAL AI** SYNTHESIZER

ROUND: 0 STATUS: AWAITING INPUT ACTIVE: —

> DEFINE THE SECURITY CHALLENGE

Create a file upload system

X START EXERCISE +1 ROUND

Examples: URL Shortener | Chat App | File Upload | Autocomplete

SOLVER
PROPOSES SOLUTION

STANDBY

AWAITING PROBLEM

BREAKER
FINDS FLAWS

STANDBY

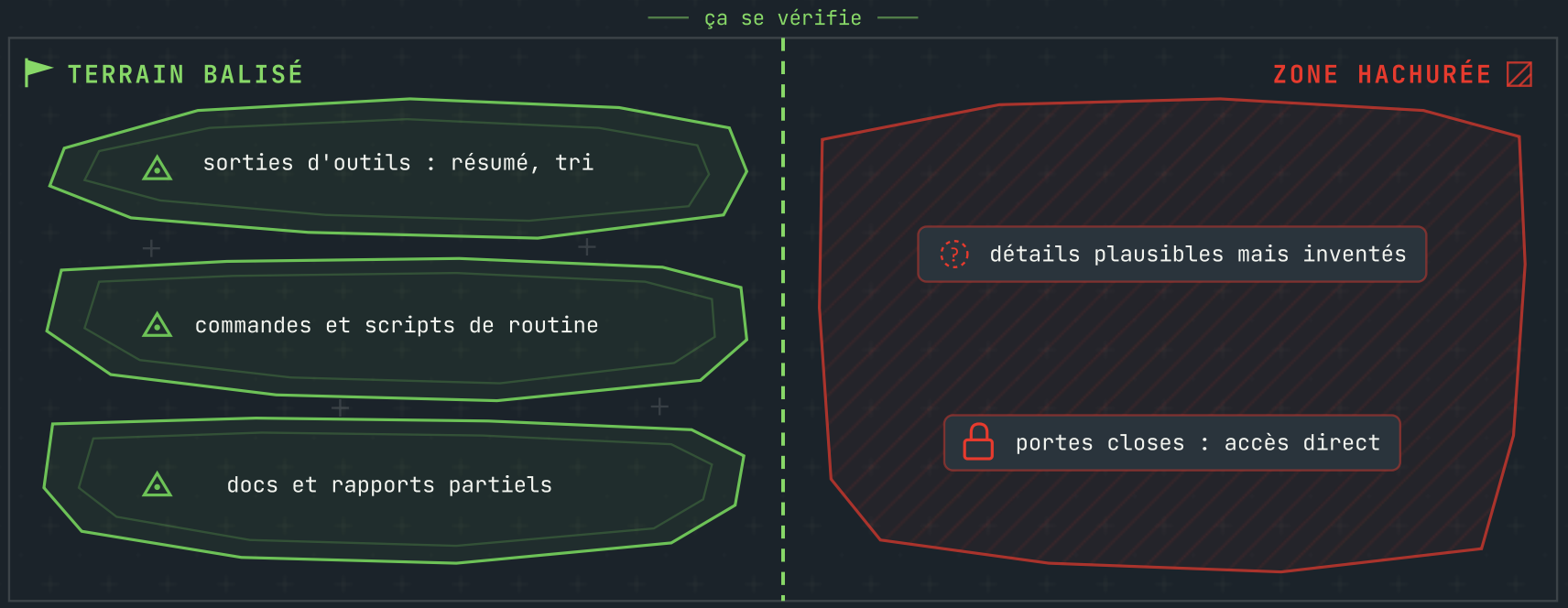
AWAITING SOLUTION

SYNTHESIZER
FINAL SOLUTION

STANDBY

AWAITING SYNTHESIS

Fiable sur tout ce qui se vérifie, fragile sur le reste

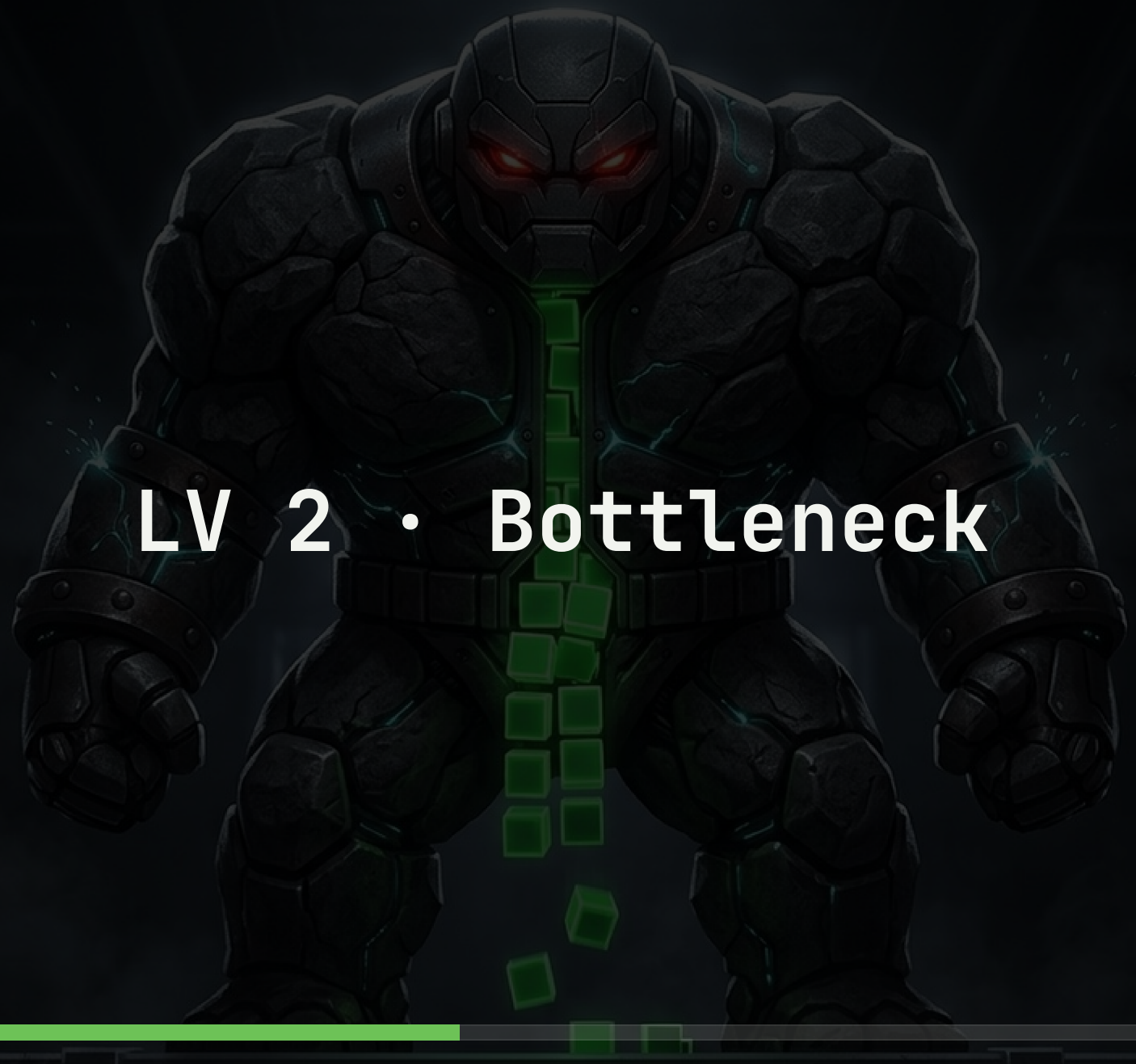


- Le flag de CTF tranche **sans doute possible**; un pentest se prouve constat par constat
- Le finicky, le « dans ta tête » : l'IA y **empile les suppositions**

La règle d'or : valider les résultats

> Jamais de résultat non vérifié dans un rapport. **Jamais.**

- La validation s'enseigne à l'agent, elle ne s'ajoute pas à la fin
- Même la sévérité s'enseigne : le kit de rapport **YesWeHack** rédige sur preuve, pas sur hype
- L'invocation qui a écrit ne valide pas son propre travail
- **L'IA propose, le pentester dispose**



LV 2 · Bottleneck

Boss № 2 : Bottleneck

BOSS 2 / 5

- Le contexte passe par **toi** : lent à taper, flou à spécifier
- Ce que tu ne précises pas, l'invocation **le suppose**
- Vite nulle part, ou vite dans le mauvais sens
- **Remède : les skills**, être spécifique dès le brief



Le contexte, c'est toi qui le portes

Tout raconter, chaque fois

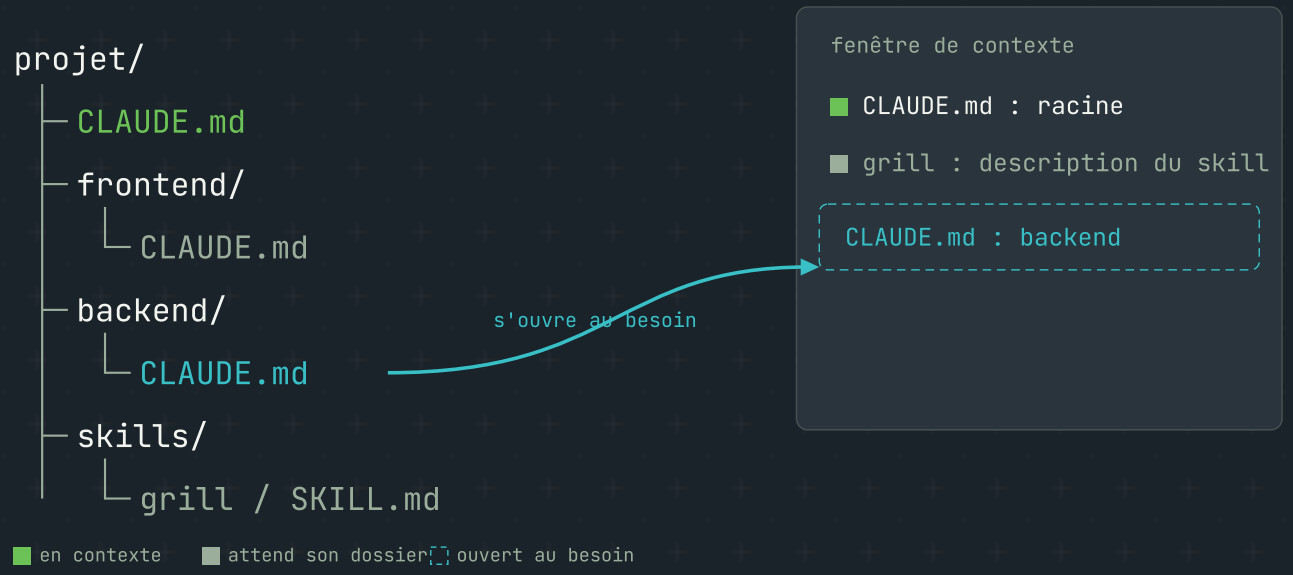
- Limité par le contexte de l'agent
- Repart de zéro à chaque changement d'agent ou de session

Progressive disclosure

- L'information en couches, chargée au besoin
- Exemple : le **skill** s'ouvre quand la mission y touche



Progressive disclosure : un guide par dossier, chargé au besoin



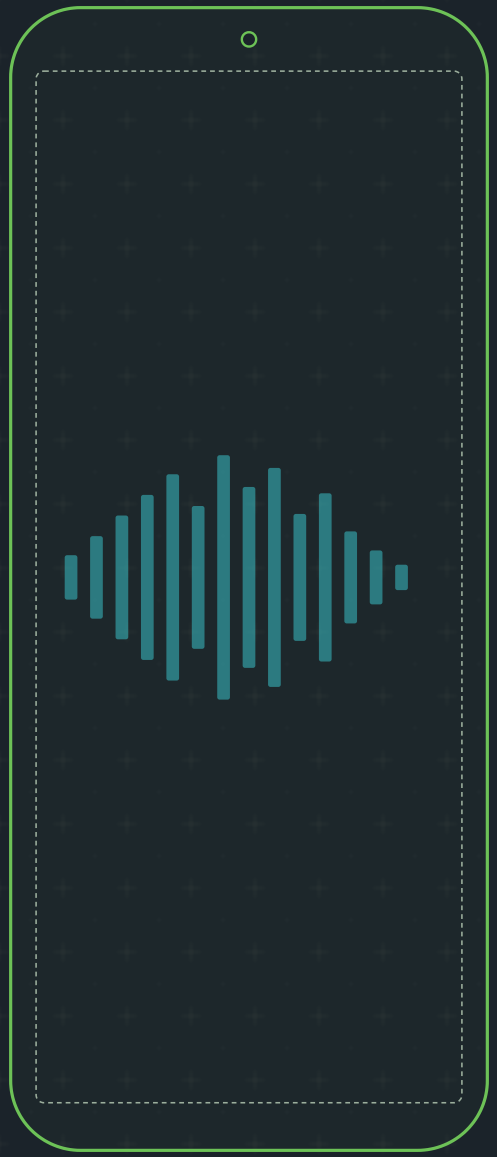
- **Un guide par dossier** : racine, frontend, backend, le skill
- **Le titre d'abord** : le contenu traverse seulement au besoin
- **`@` référence un fichier** : `@docs/api.md` dans le guide, chargé avec lui

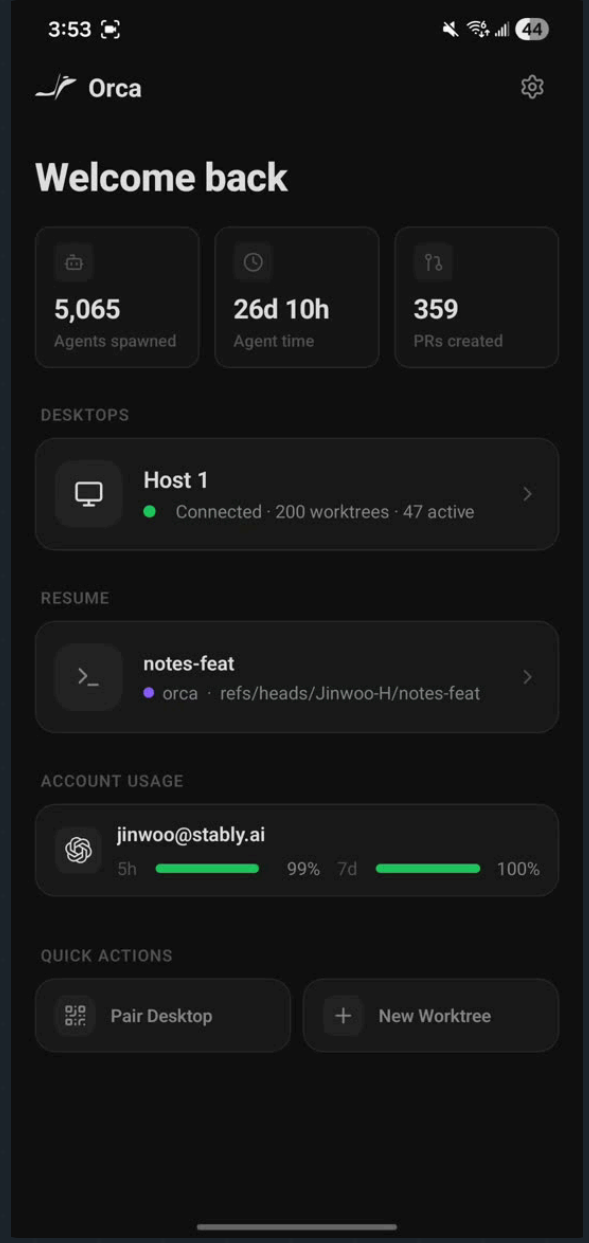
Boss Bottleneck : premier contre, la voix

189
mots/min · la voix

98
mots/min · le clavier

~1,9x
les mains libres

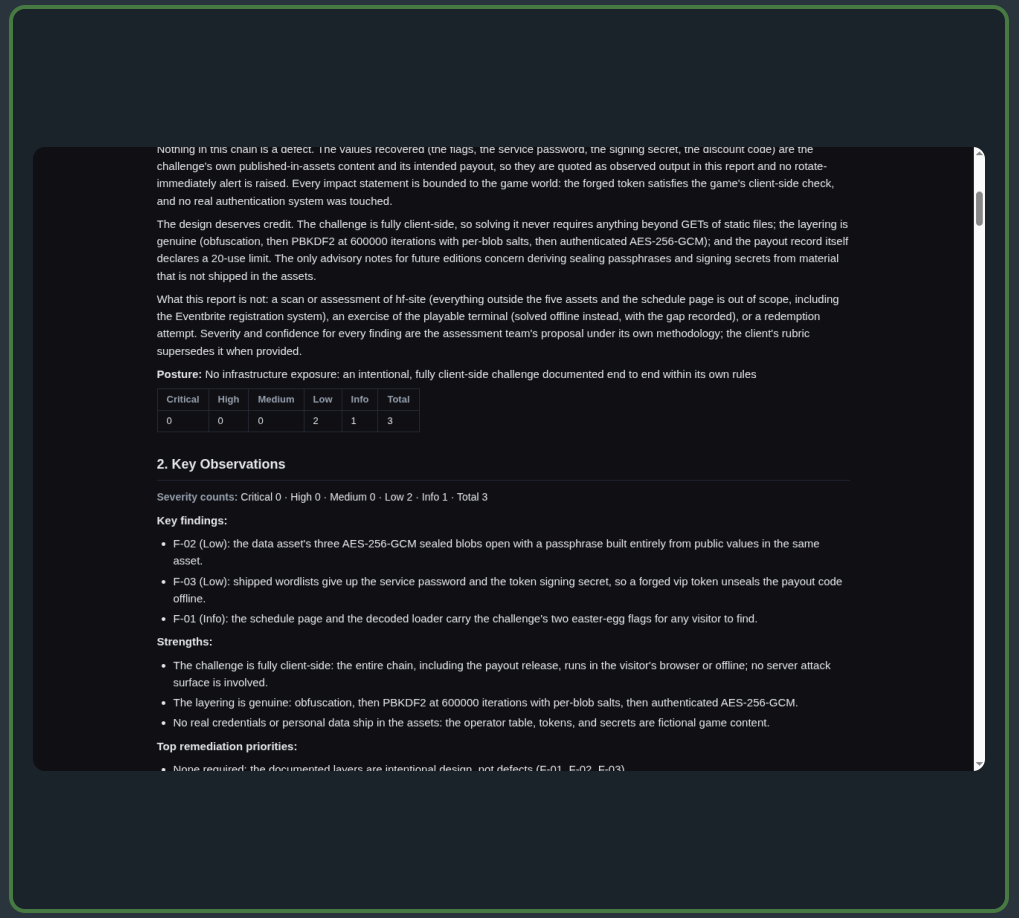




handy.computer

wisprflow.ai

Exemple réel № 1 : le rapport de pentest



Nothing in this chain is a defect. The values recovered (the flags, the service password, the signing secret, the discount code) are the challenge's own published-in-assets content and its intended payout, so they are quoted as observed output in this report and no rotate-immediately alert is raised. Every impact statement is bounded to the game world: the forged token satisfies the game's client-side check, and no real authentication system was touched.

The design deserves credit. The challenge is fully client-side, so solving it never requires anything beyond GETs of static files; the layering is genuine (obfuscation, then PBKDF2 at 600000 iterations with per-blob salts, then authenticated AES-256-GCM); and the payout record itself declares a 20-use limit. The only advisory notes for future editions concern deriving sealing passphrases and signing secrets from material that is not shipped in the assets.

What this report is not: a scan or assessment of hf-site (everything outside the five assets and the schedule page is out of scope, including the Eventbrite registration system), an exercise of the playable terminal (solved offline instead, with the gap recorded), or a redemption attempt. Severity and confidence for every finding are the assessment team's proposal under its own methodology; the client's rubric supersedes it when provided.

Posture: No infrastructure exposure: an intentional, fully client-side challenge documented end to end within its own rules

Critical	High	Medium	Low	Info	Total
0	0	0	2	1	3

2. Key Observations

Severity counts: Critical 0 · High 0 · Medium 0 · Low 2 · Info 1 · Total 3

Key findings:

- F-02 (Low): the data asset's three AES-256-GCM sealed blobs open with a passphrase built entirely from public values in the same asset.
- F-03 (Low): shipped wordlists give up the service password and the token signing secret, so a forged vip token unseals the payout code offline.
- F-01 (Info): the schedule page and the decoded loader carry the challenge's two easter-egg flags for any visitor to find.

Strengths:

- The challenge is fully client-side: the entire chain, including the payout release, runs in the visitor's browser or offline; no server attack surface is involved.
- The layering is genuine: obfuscation, then PBKDF2 at 600000 iterations with per-blob salts, then authenticated AES-256-GCM.
- No real credentials or personal data ship in the assets: the operator table, tokens, and secrets are fictional game content.

Top remediation priorities:

- None required: the documented layers are intentional design, not defects (F-01, F-02, F-03)

pentest-workflow + **pentest-reporter**, capture réelle

- Le rapport : la partie du mandat qui mange le temps
- Des preuves et notes vers des sections rédigées
- Constats et sévérités d'un vrai engagement
- Prompt **remédiation** : les correctifs recommandés, constat par constat
- Prompt **retest** : rejouer la preuve après correction
- L'humain reste **QA et chef de projet** : garder le scope, bâtir le sandbox (agentbox)
- Valider que tout est **vrai** + la **criticité** de chaque constat

Nothing in this chain is a defect. The values recovered (the flags, the service password, the signing secret, the discount code) are the challenge's own published-in-assets content and its intended payout, so they are quoted as observed output in this report and no rotate-immediately alert is raised. Every impact statement is bounded to the game world: the forged token satisfies the game's client-side check, and no real authentication system was touched.

The design deserves credit. The challenge is fully client-side, so solving it never requires anything beyond GETs of static files; the layering is genuine (obfuscation, then PBKDF2 at 600000 iterations with per-blob salts, then authenticated AES-256-GCM); and the payout record itself declares a 20-use limit. The only advisory notes for future editions concern deriving sealing passphrases and signing secrets from material that is not shipped in the assets.

What this report is not: a scan or assessment of hf-site (everything outside the five assets and the schedule page is out of scope, including the Eventbrite registration system), an exercise of the playable terminal (solved offline instead, with the gap recorded), or a redemption attempt. Severity and confidence for every finding are the assessment team's proposal under its own methodology; the client's rubric supersedes it when provided.

Posture: No infrastructure exposure: an intentional, fully client-side challenge documented end to end within its own rules

Critical	High	Medium	Low	Info	Total
0	0	0	2	1	3

2. Key Observations

Severity counts: Critical 0 · High 0 · Medium 0 · Low 2 · Info 1 · Total 3

Key findings:

- F-02 (Low): the data asset's three AES-256-GCM sealed blobs open with a passphrase built entirely from public values in the same asset.
- F-03 (Low): shipped wordlists give up the service password and the token signing secret, so a forged vip token unseals the payout code offline.
- F-01 (Info): the schedule page and the decoded loader carry the challenge's two easter-egg flags for any visitor to find.

Strengths:

- The challenge is fully client-side: the entire chain, including the payout release, runs in the visitor's browser or offline; no server attack surface is involved.
- The layering is genuine: obfuscation, then PBKDF2 at 600000 iterations with per-blob salts, then authenticated AES-256-GCM.
- No real credentials or personal data ship in the assets: the operator table, tokens, and secrets are fictional game content.

Top remediation priorities:

- None required: the documented layers are intentional design, not defects (F-01, F-02, F-03).

CAPABILITY WIKI

Everything pentest-reporter can show as evidence

Not a report — a **catalog of the building blocks**. Every way this project turns a finding into citable, trustworthy visual evidence, each shown live with the exact command that produces it. **Every artifact here is real**: demos run live against an authorized local stand-in target (`127.0.0.1:8899` , reached on-narrative as `app.acme.example` via `curl --resolve`) serving a dummy `/.env` — real curl output, real browser captures, real annotations on them.

authorized · local demo target | live, not mocked | dummy secrets only | read-only capture

12 CAPABILITIES

12 LIVE ARTIFACTS

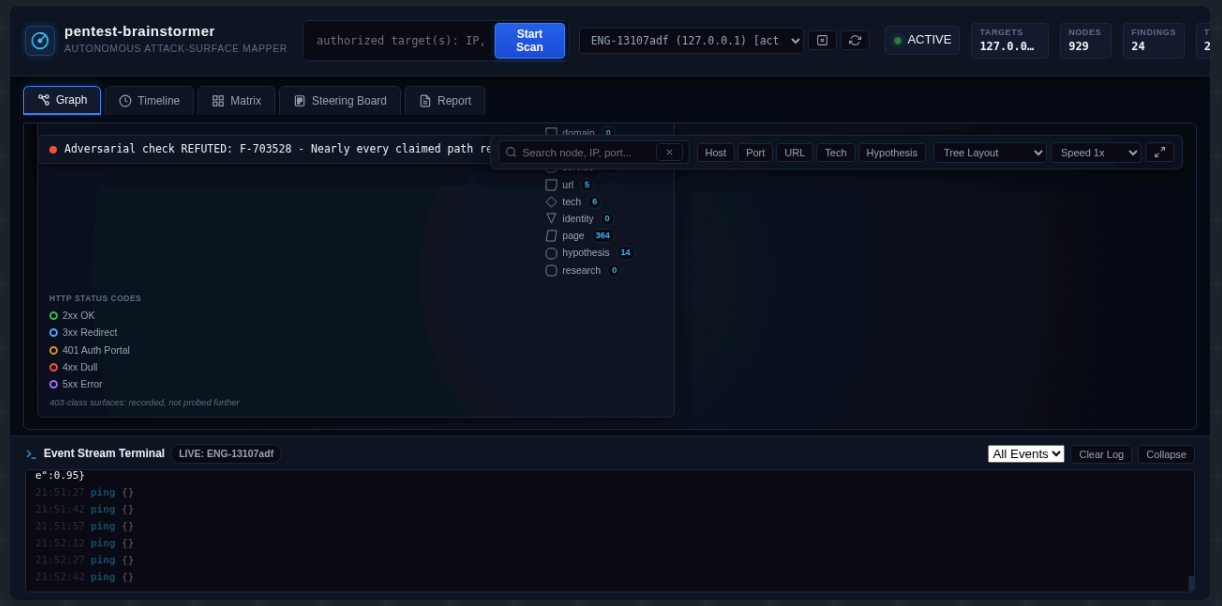
6 CATEGORIES

JUMP TO Quote & replay Verbatim terminal output Replay the shell session Expected vs observed Highlight Highlight a terminal prompt Mark the evidence with a red box Multiple labeled boxes Crop & zoom the evidence Capture A raw browser capture Redact Redact secrets by location Diagram ASCII attack-surface diagram SVG vector diagram Classify Severity & confidence pills

QUOTE & REPLAY

3 capabilitys

Exemple réel № 2 : cartographier la surface d'attaque



- Je ne donne plus des commandes, je donne une **mission** : « cartographie-moi la surface d'attaque »
- Invocations en parallèle : fouiller le web, énumérer, croiser les sources
- Container **jetable et durci** (agentbox), base Kali minimal : l'invocation installe ou crée ses outils
- Ce que ça produit : **pentest-brainstormer**, le graphe à l'écran (capture réelle)
- **500+ endpoints API** énumérés, **chacun validé par script** : jamais fait à la main avant
- **L'IA rassemble, l'humain décide** : plus de preuve pour **mieux choisir où frapper**

pentest-brainstormer
AUTONOMOUS ATTACK-SURFACE MAPPER

authorized target(s): IP, | Start Scan | ENG-88c228bc (172.28.40.10, 1 | ACTIVE | TARGETS 172.28.40.10, 172.… | NOD 91

Graph | Timeline | Matrix | Steering Board | Report



Search node, IP, port... | Host | Port | URL | Tech | Hypothesis | Tree Layout | Speed 3x

ATTACK-SURFACE GLYPHS & STATES 7 nodes | 7 links

Event Stream Terminal | LIVE: ENG-88c228bc | All Events | Clear Log | Collapse

```
17:20:07 select ENG-88c228bc
17:20:07 connect /api/engagements/ENG-88c228bc/events
17:20:07 hello {"engagement":"ENG-88c228bc"}
```

> /skill grilling je veux un script qui exporte chaque nuit les nouveaux événements du SIEM vers une archive froide S3

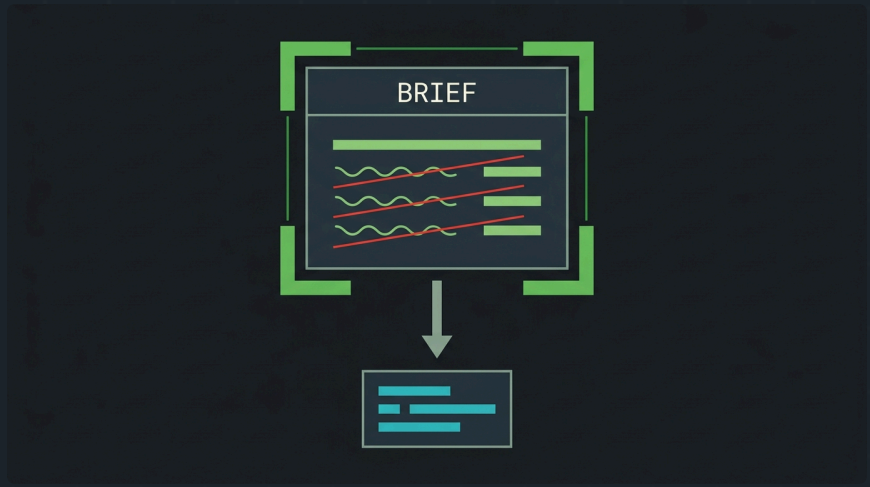
voici la première salve de questions, celles dont rien ne bloque la réponse.

▯ **Q1** - **Quel SIEM ?** : Splunk, Elastic, IBM QRadar, Microsoft Sentinel, Wazuh, Graylog, autre ? C'est la décision racine : elle détermine toute la méthode d'extraction…
→ Ma recommandation : je ne peux pas deviner — mais si vous hésitez encore, Splunk ou Elastic…
▯ **Q2** - **Périmètre et volume** : Tous les événements, ou un sous-ensemble ? Et l'ordre de grandeur par nuit : 500 Mo, 10 Go, 500 Go ?
▯ **Q3** - **Que veut dire « nouveaux » ?** : Fenêtre fixe J-1 ou fenêtre glissante 24 h ? Basée sur l'heure d'**ingestion** ou l'heure **horodatée** ? Garde un point de reprise persistant (watermark) ou recalcule la fenêtre chaque nuit ? Et que faire si le script tourne deux fois la même nuit ?
▯ **Q4** - **Quelle cible S3 ?** : Vrai AWS S3, ou stockage compatible S3 (MinIO on-prem, Scaleway, OVH, Exoscale) ? Un seul bucket, quel schéma de préfixes (`siem-export/dt=2026-10-25/` ?), et classe de stockage
▯ **Q5** - **Format et compression** : NDJSON gzippé ? CSV ? Parquet (colonnaire, compact) ?
▯ **Q6** - **Où et quand s'exécute le script ?** : Cron ou timer systemd, conteneur planifié, Lambda, orchestrateur type Airflow ? avec quel timeout max acceptable ?
▯ **Q7** - **Authentification et secrets** : compte de service dédié, token API ? Clés statiques, rôle IAM / instance profile, OIDC ? Où sont stockés les secrets ?
▯ **Q8** - **Fiabilité, alerting, intégrité** : retry automatique combien de fois ? Qui est prévenu, et comment ? checksums, manifeste, re-déchiffrement test ?
▯ **Q9** - **Conformité et rétention** : Durée de conservation visée ? Exigences d'immuabilité légale (Object Lock / WORM…) ?
▯ **Q10** - **Comment relira-t-on l'archive ?** : Réinjection dans un SIEM en cas d'incident, requêtes Athena/Spark, simple conservation pour audit jamais relue ?

Répondez à ces dix questions (un mot suffit souvent), et je repartirai avec la salve 2 : choix exact d'API et pagination selon le SIEM, mécanisme de checkpoint, stratégie de dédup, gestion des limites de débit.

№ 2 attaqué : enseigner les skills dès le brief

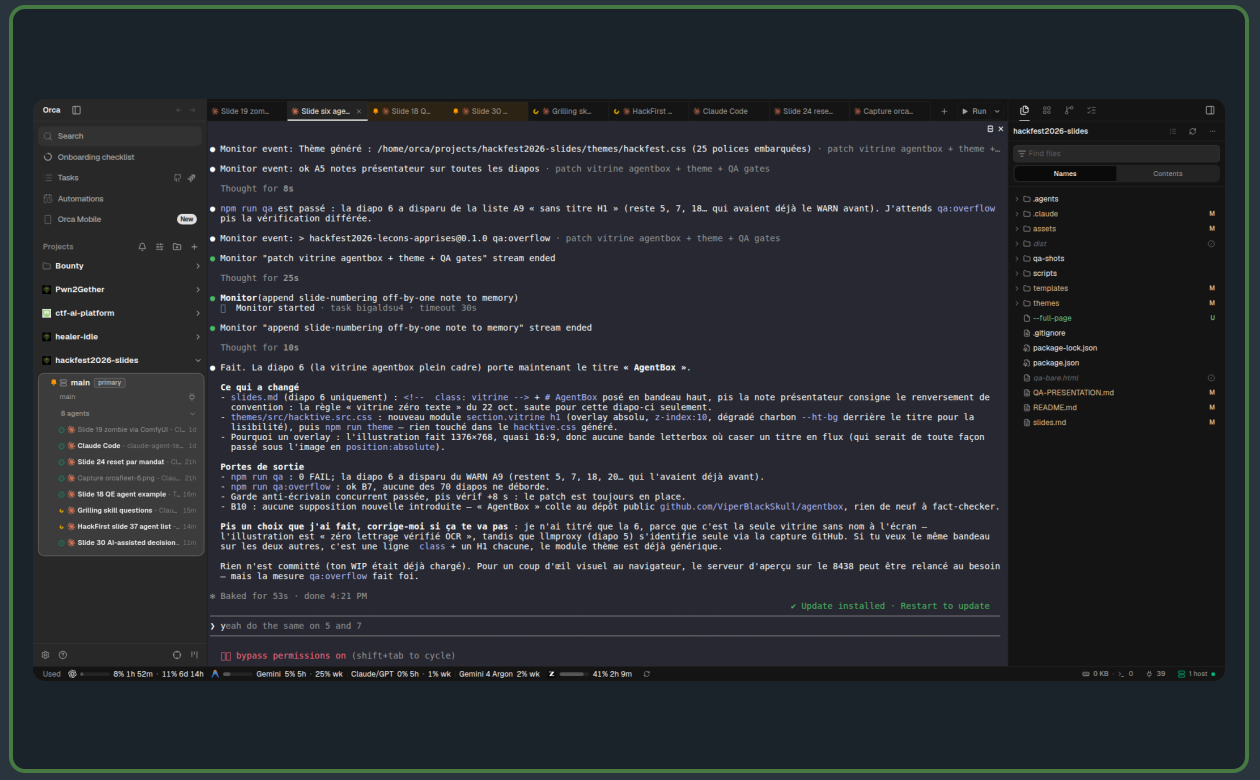
- L'ambiguïté se règle **au brief**, pas après coup
- Enseigné une fois, **reproduit** à chaque mandat
- Demander « sur quoi tu bases ça? » fait tomber la pile





LV 3 · Le chaos

Orca : plusieurs agents en parallèle, un seul capitaine



Orca, mon environnement de développement d'agents, capturé en direct

- Je briefe, je lève, je supervise : **un seul écran**
- Chaque agent : **son worktree Git**, sa mission
- Le swarm reste **contrôlé**, jamais lâché

● Monitor event: Thème généré : /home/orca/projects/hackfest2026-slides/themes/hackfest.css (25 polices embarquées) · patch vitrine agentbox + theme +…

● Monitor event: ok A5 notes présentateur sur toutes les diapos · patch vitrine agentbox + theme + QA gates

Thought for 8s

● npm run qa est passé : la diapo 6 a disparu de la liste A9 « sans titre H1 » (reste 5, 7, 18… qui avaient déjà le WARN avant). J'attends qa:overflow pis la vérification différée.

● Monitor event: > hackfest2026-lecons-apprises@0.1.0 qa:overflow · patch vitrine agentbox + theme + QA gates

● Monitor "patch vitrine agentbox + theme + QA gates" stream ended

Thought for 25s

● **Monitor**(append slide-numbering off-by-one note to memory)
  Monitor started · task bigaldsu4 · timeout 30s

● Monitor "append slide-numbering off-by-one note to memory" stream ended

Thought for 10s

● Fait. La diapo 6 (la vitrine agentbox plein cadre) porte maintenant le titre « **AgentBox** ».

Ce qui a changé
- slides.md (diapo 6 uniquement) : <!-- class: vitrine --> + # AgentBox posé en bandeau haut, pis la note présentateur consigne le renversement de convention : la règle « vitrine zéro texte » du 22 oct. saute pour cette diapo-ci seulement.
- themes/src/hacktive.src.css : nouveau module section.vitrine h1 (overlay absolu, z-index:10, dégradé charbon --ht-bg derrière le titre pour la lisibilité), puis npm run theme — rien touché dans le hacktive.css généré.
- Pourquoi un overlay : l'illustration fait 1376×768, quasi 16:9, donc aucune bande letterbox où caser un titre en flux (qui serait de toute façon passé sous l'image en position:absolute).

Portes de sortie
- npm run qa : 0 FAIL; la diapo 6 a disparu du WARN A9 (restent 5, 7, 18, 20… qui l'avaient déjà avant).
- npm run qa:overflow : ok B7, aucune des 70 diapos ne déborde.
- Garde anti-écrivain concurrent passée, pis vérif +8 s : le patch est toujours en place.
- B10 : aucune supposition nouvelle introduite — « AgentBox » colle au dépôt public github.com/ViperBlackSkull/agentbox, rien de neuf à fact-checker.

Pis un choix que j'ai fait, corrige-moi si ça te va pas : je n'ai titré que la 6, parce que c'est la seule vitrine sans nom à l'écran — l'illustration est « zéro lettrage vérifié OCR », tandis que llmproxy (diapo 5) s'identifie seule via la capture GitHub. Si tu veux le même bandeau sur les deux autres, c'est une ligne class + un H1 chacune, le module thème est déjà générique.

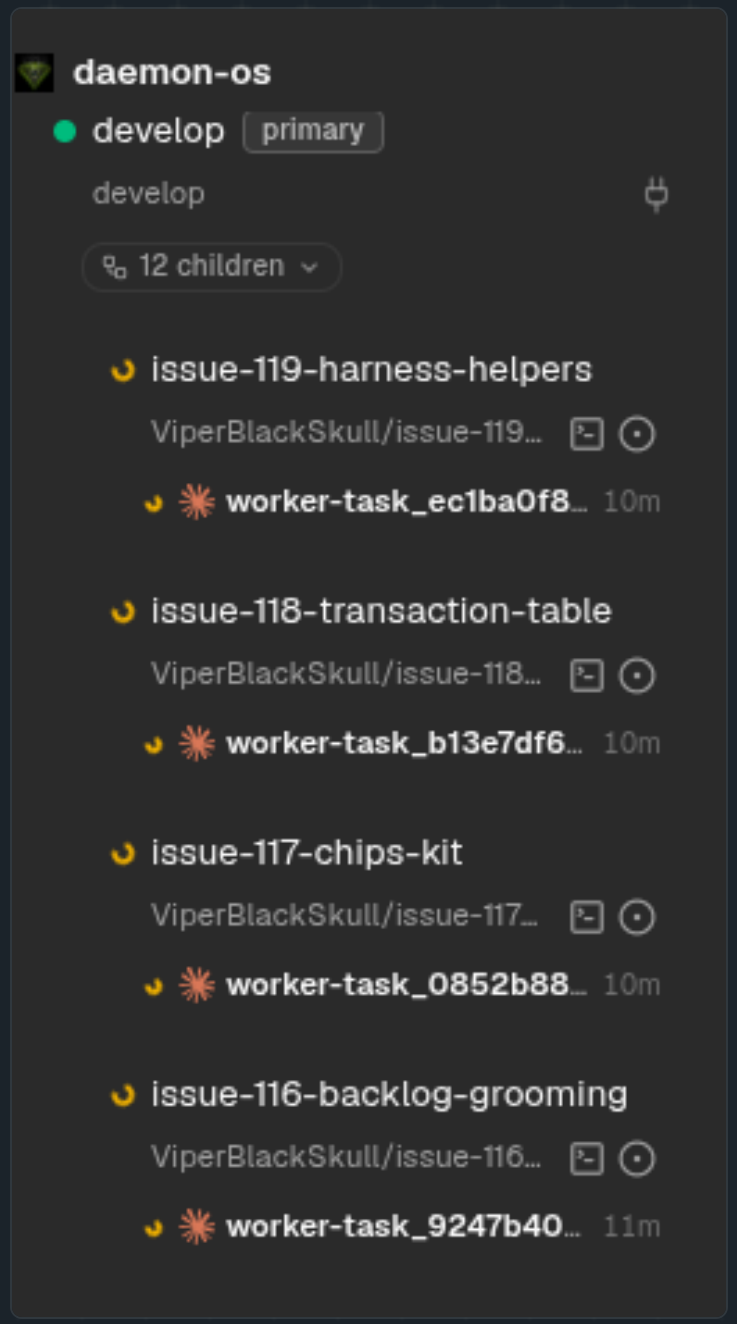
Rien n'est committé (ton WIP était déjà chargé). Pour un coup d'œil visuel au navigateur, le serveur d'aperçu sur le 8438 peut être relancé au besoin — mais la mesure qa:overflow fait foi.

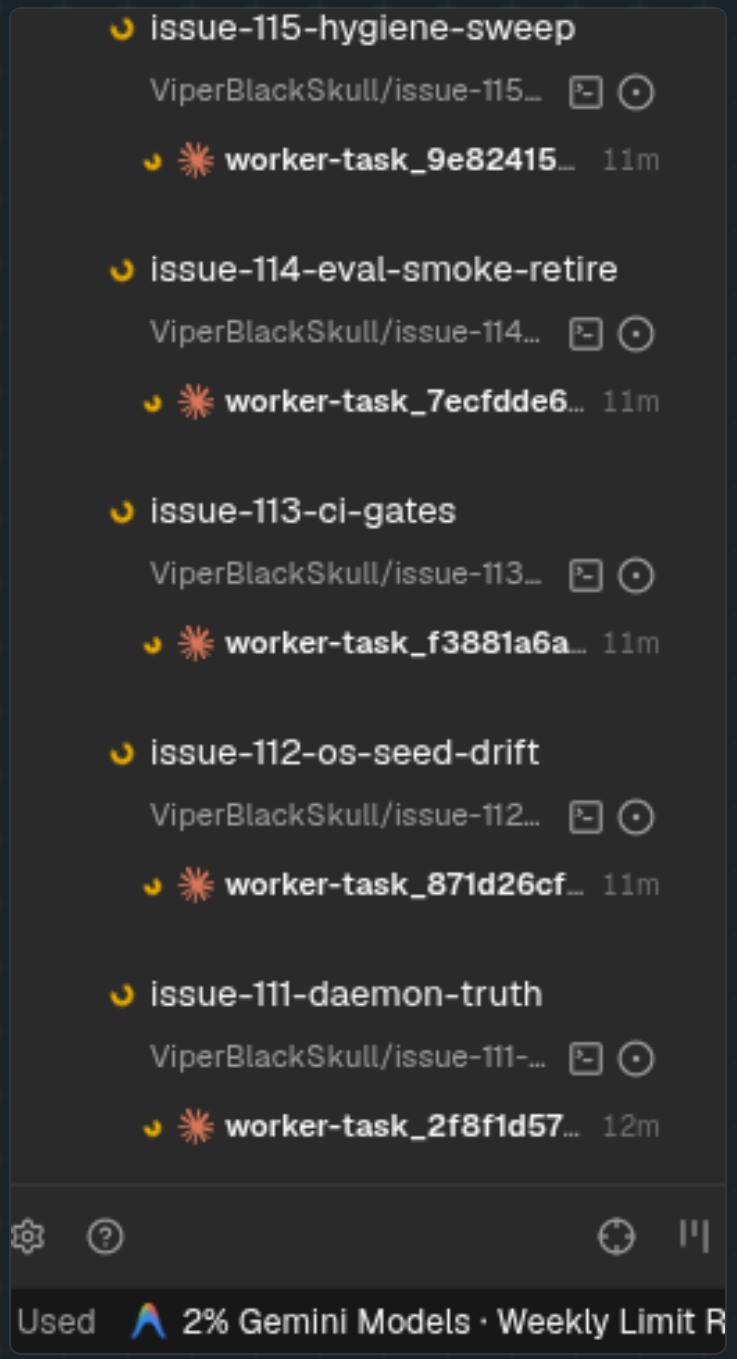
* Baked for 53s · done 4:21 PM

✔ Update installed · Restart to update

❯ yeah do the same on 5 and 7

⏸⏸ bypass permissions on (shift+tab to cycle)



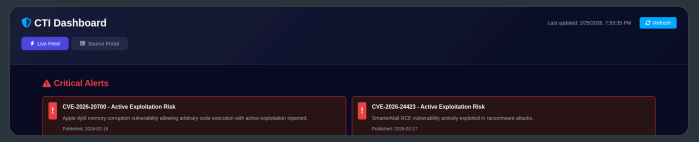


Une mission par worktree

Orca, la barre latérale de la flotte, repliée en deux colonnes

- **develop | primary**, 12 enfants : une branche par mission
- Chaque issue : **son worktree**, son invocation **worker-task**
- Le swarm au complet, **d'un coup d'œil**

Mes projets : les principaux pis les essais que j'ai tentés



cti-dashboard

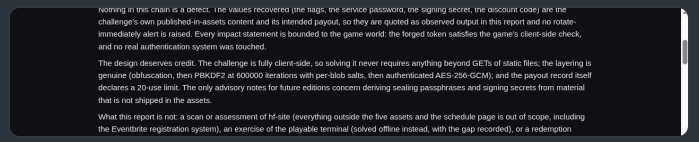


mission-control

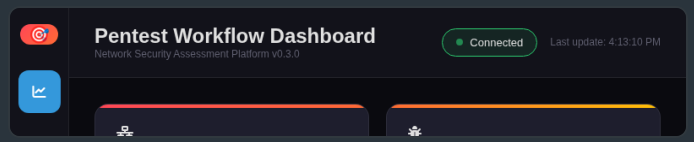


agentbox

publique



pentest-reporter

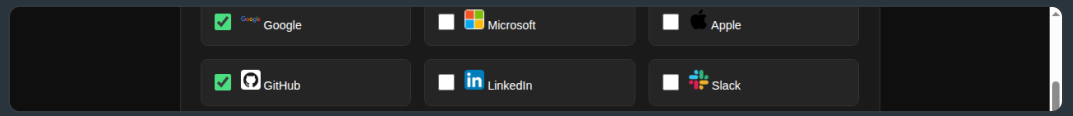


pentest-workflow



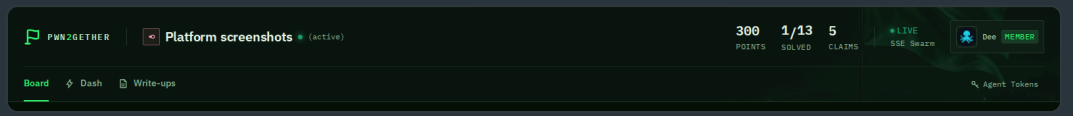
guardian

publique



checkup

checkup.hacktive.education



Pwn2Gether

Boss № 3 : le chaos

BOSS 3 / 5

- L'autonomie sans guardrails : **des fichiers créés partout**, au hasard
- Sur ta propre machine, **ça peut tout casser**
- Un guardrail écrit dans ton contexte n'est qu'une **guideline** : le modèle peut l'ignorer
- **Remède : l'agentbox** : sa propre machine, l'autonomie dans un environnement contrôlé

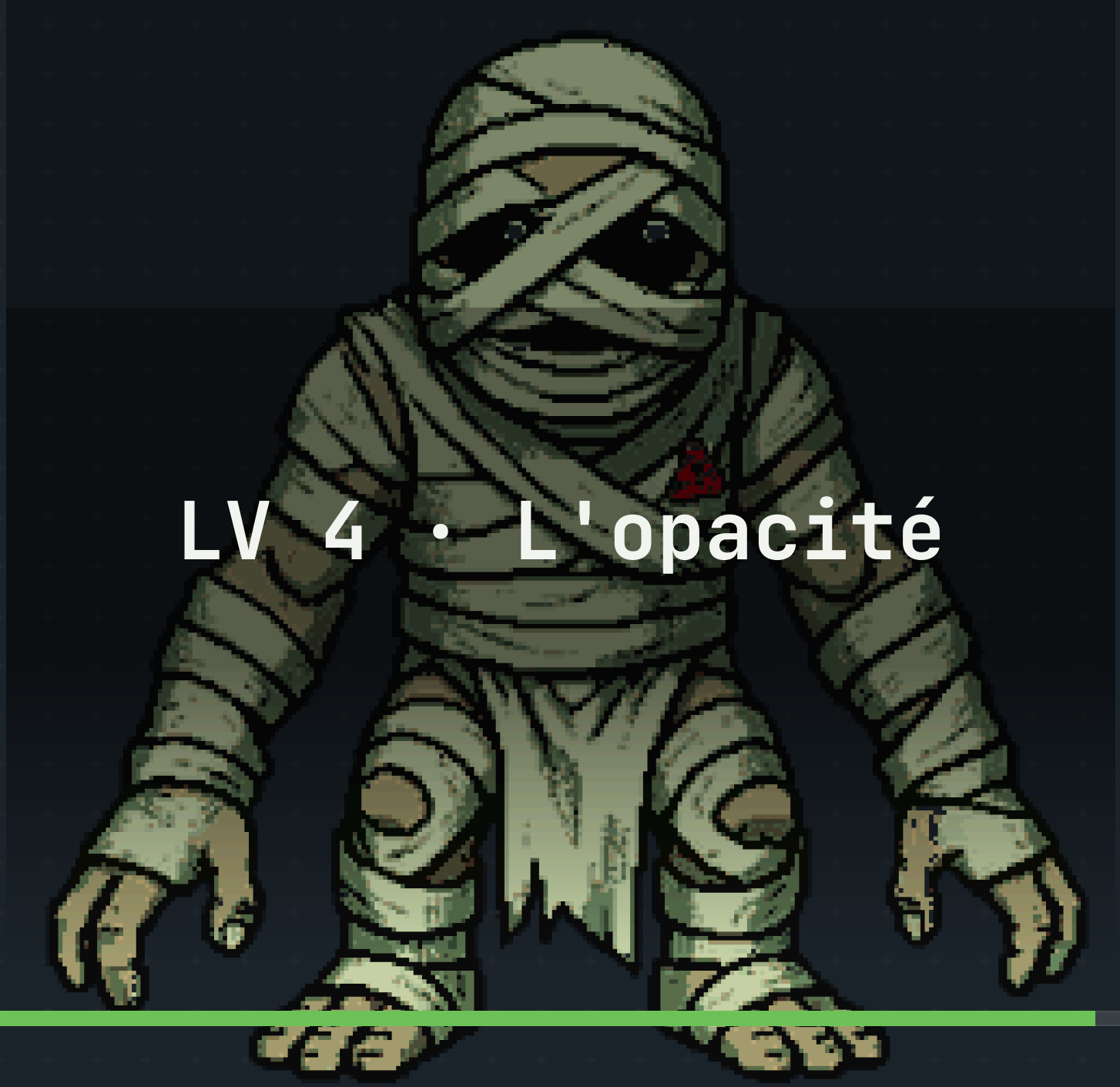


№ 3 attaqué : l'agentbox, sa propre machine

- **Sa propre machine** : le container jetable pis durci, pas ton laptop
- L'autonomité **reste entière** : sudo sans mot de passe, l'invocation s'autoconfigure pis installe ses outils
- **Zéro clé API dans l'environnement** : rien à voler quand c'est compromis
- La casse **contenue** : environnement contrôlé, jetable après la mission



```
[viper@MainArch ~]$
```



LV 4 · L'opacité

Boss № 4 : l'opacité

BOSS 4 / 5

- Le cron **échoue en silence** : personne ne le voit tomber
- La recherche **échoue en silence** : des résultats creux pris pour des faits
- **Sans proxy**, rien à observer : tu ne vois pas ce qui se passe
- **Remède : le LLM proxy**, tout le trafic devient observable



La momie : ses yeux sont bandés

```
● Fetch(https://www.reddit.com/r/netsec/)
  └ Error: Claude Code is unable to fetch from www.reddit.com
```



Claude Code vs Reddit : toutes les routes bloquées

- Accès direct impossible, porte close
- Gemini **lit la vidéo YouTube**, image et son
- ChatGPT **ne peut pas**, du lien seul : il propose le détour de la transcription
- Sans l'outil adapté, la momie **devine**
- Réflexe : connaître les sens de chaque invocation, ou lui donner des yeux (tools)

● **Fetch**(https://www.reddit.com/r/netsec/)
  ⎿ Error: Claude Code is unable to fetch from www.reddit.com

№ 4 attaqué : le LLM proxy rend tout observable

- **LLM proxy** : chaque appel du modèle passe, journalisé, inspectable
- **LangSmith** : l'alternative quand le projet existe déjà
- L'opacité se règle par **l'infrastructure**, pas par la confiance

Lui donner des yeux : mes MCP de choix

MCP (Model Context Protocol) : la prise standard pour brancher des outils

`playwright`

Un vrai navigateur piloté : naviguer, cliquer, remplir

`browser_use`

L'agent navigue et décide de lui-même, page après page

`interceptor`

Le trafic réseau sous les yeux : requêtes et réponses

`camofox`

Le navigateur discret : voir sans se faire repérer

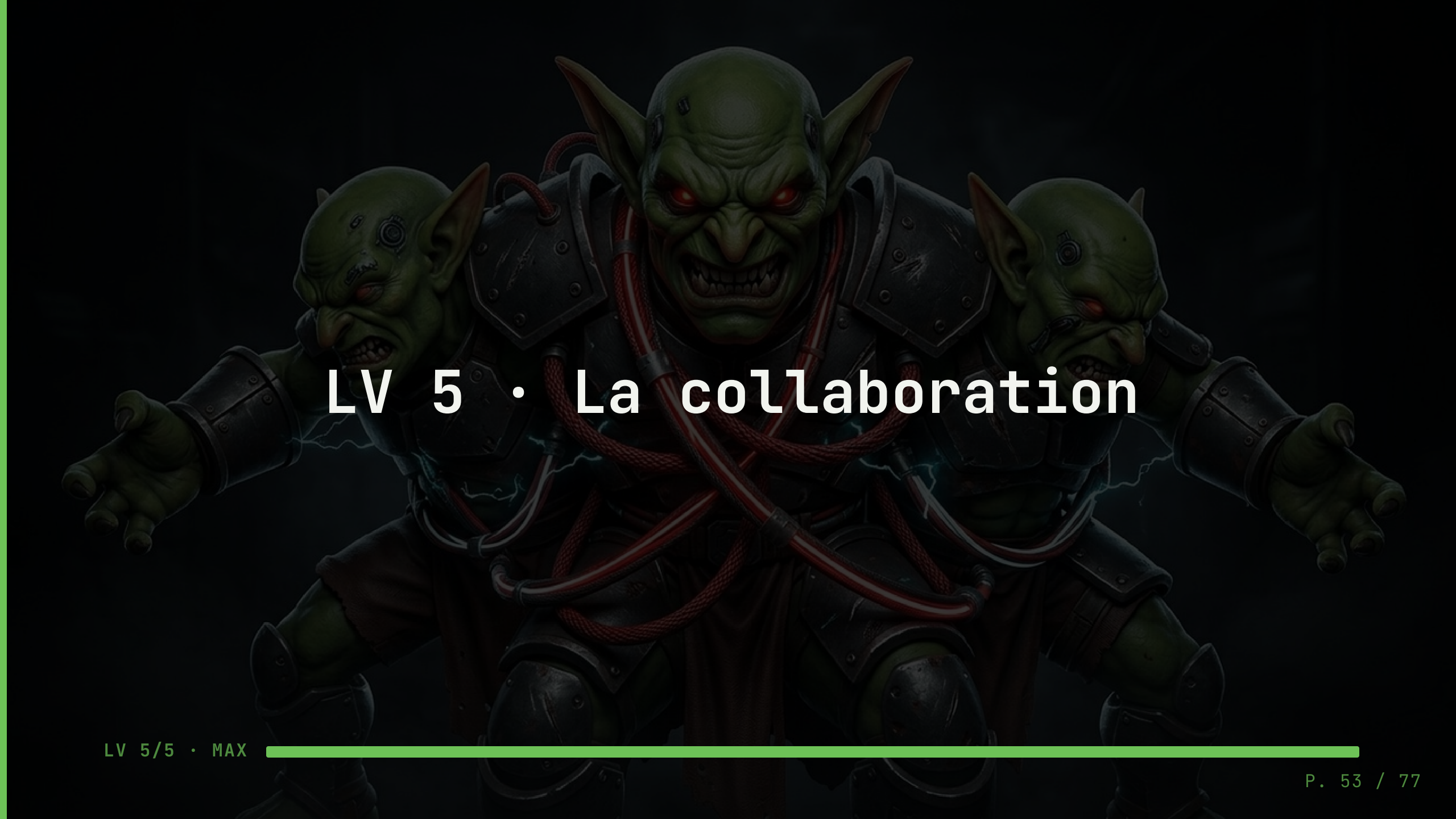
La checklist de preuves : « c'est fait » se vérifie

Sur parole

- « C'est fait » : l'affirmation
- état « complété » : l'affichage

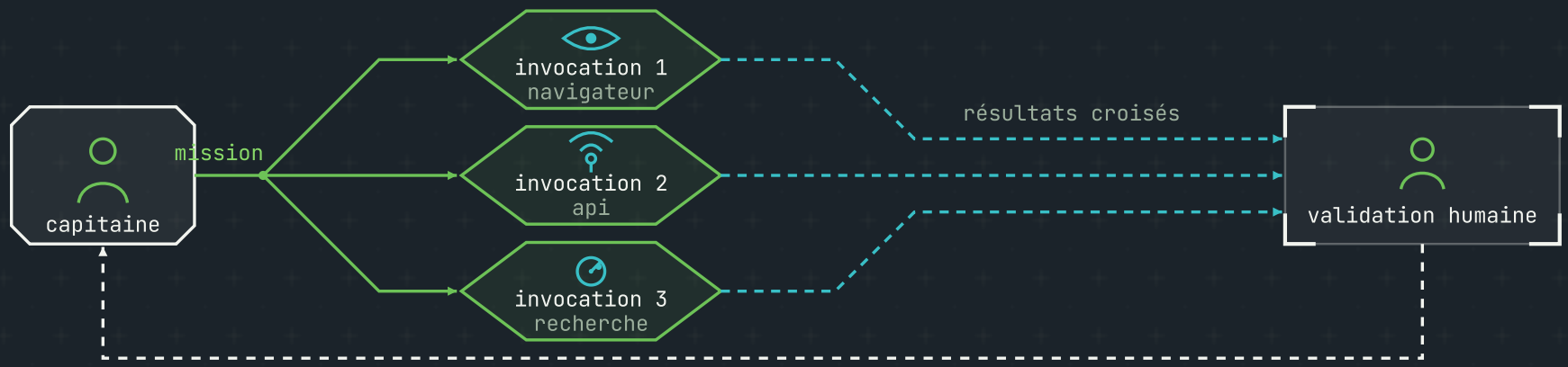
Sur pièces, en markdown

- [x] fichiers modifiés : `git status`
- [x] tests verts : sortie 0
- [ ] log du cron : horodaté ce matin
- [ ] capture : fichier du jour



LV 5 · La collaboration

L'Invocateur : des invocations en co-op



L'IA accélère le travail, elle ne remplace pas la pensée, le goût, la décision.

Boss № 5 : la collaboration

BOSS 5 / 5

- **Multijoueur** : plusieurs humains, plusieurs invocations en temps réel, une mission, **chacun sa route**
- Le travail **se marche dessus**, se duplique, se perd
- **Remède : itsaplan**, un seul plan pour tout le swarm



We launched on Product Hunt today. See the launch

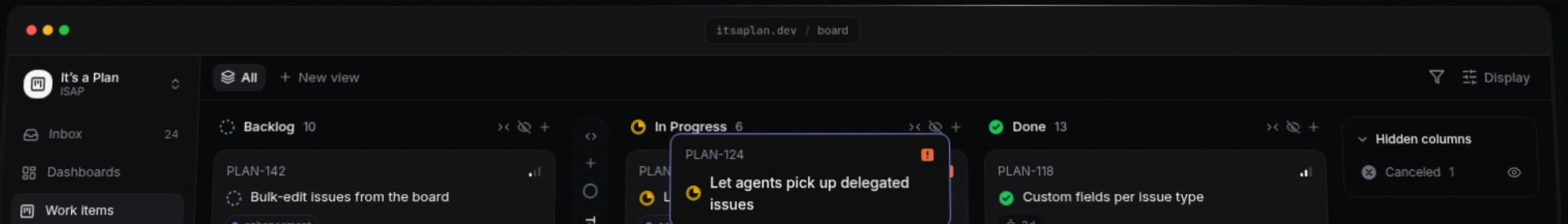
Open source See how it compares to Linear →

The issue tracker where people and AI agents ship together.

It's a Plan is the open source alternative to Linear, Jira, and Plane. Project management for any team, on your own server, with AI agents as teammates.

Self-host → One-click deploy on Railway →

AGPL-3.0 · No per-seat fees · Bring your own model keys



№ 5 attaqué : itsaplan, un seul plan pour tout le swarm

- Le plan **découpé en cartes** : l'invocation tire la prochaine, elle n'invente pas son périmètre
- Le **cap et le progrès de chacun** : visibles, invocations comme humains
- Coincée deux fois : la carte **revient à l'humain**

Backlog 6

HI-112
Constrained zone/event PCG — banked until content volume is the bottleneck
48d · lane:next · size:M
Created Sep 4 · Updated Sep 4

HI-43
Install ACE-Step music weights on the ComfyUI box
42d · lane:user-action · size:S
Created Sep 2 · Updated Sep 10

HI-89
SS-P3 — Launch runway
42d · lane:next · size:M
Created Sep 3 · Updated Sep 29

HI-369
Play.fun / OGP monetization — parked evaluation (Viper-only)
36d · lane:gate
Created Sep 15 · Updated Sep 15

HI-445
Fine cuts — per-drop rarity rolls on gear (parked)
23d · lane:user-action
Created Sep 29 · Updated Sep 29

HI-482
Design law (Viper 2026-09-29): NO healing-momentum mechanic — never...
23d · lane:gate
Created Sep 29 · Updated Sep 29

Todo 35

HI-88
SS-P2 — Store page + demo
36d · lane:next · size:L
Created Sep 3 · Updated Sep 29

HI-87
SS-P1 — Electron + Steamworks MVP
36d · lane:next · human:review · size:L
Created Sep 3 · Updated Sep 29

HI-301
Full actor animation repaint — companions + every monster family
39d · lane:next · size:XL · needs-comfyui
Created Sep 13 · Updated Sep 29

HI-176
Produce the Steam art package — healer key art, logo, capsules, app icons
36d · lane:gate · size:L · human:review · needs-comfyui
Created Sep 5 · Updated Sep 29

HI-446
Board ops (gated): Better Auth sees no client IPs — every LAN login shares ON...
23d · lane:gate
Created Sep 29 · Updated Sep 29

HI-471
The ask: the hearth-card — camp arrival becomes ONE calm panel over the...
23d

In Progress 3

HI-282
The pixel-parity repaint lost the backdrop beauty — bring the painterly stage back...
7d · lane:next · size:M · needs-comfyui
Created Sep 11 · Updated Oct 14

HI-488
The Hearth — tend the campfire to shorten recovery (camp downtime activity 1/2)
20d
Created Sep 29 · Updated Oct 1

HI-612
HI-609 bank 3/12 — the statistics page: total heals, HPS peak, per-zone time,...
18h
Created Oct 20 · Updated Oct 21

Done 135

HI-366
Camp recovery is real time — th revives and heals over ~1 minut
23d · lane:next · size:M
Created Sep 14 · Updated Sep 29

HI-368
Public web demo on GitHub Pa dist-only public repo (Steam fu
27d · lane:next · size:M
Created Sep 15 · Updated Sep 24

HI-436
RESCUE stranded wl/w-054128 (HI-432) — merge retries exhau
23d · lane:next
Created Sep 24 · Updated Sep 29

HI-438
RESCUE stranded wl/w-134536 (HI-437) — merge retries exhau
27d · lane:next
Created Sep 24 · Updated Sep 24

HI-437
RESCUE stranded wl/w-071430 (HI-435) — merge retries exhau
27d · lane:next
Created Sep 24 · Updated Sep 24

HI-439
Viper action: ack the Pages den list and say go — then npm run.
22d · size:S

Le plan est partagé, les fichiers non

Un seul dossier, toutes dedans

- Deux invocations, **le même fichier** : la dernière écriture gagne
- Sans le voir : **le travail se marche dessus**

Un worktree Git par invocation

- `git worktree add` : **un dossier par branche**, sans re-cloner
- Chacune dans le sien : **zéro collision**
- Fusion après validation : **l'humain tranche**

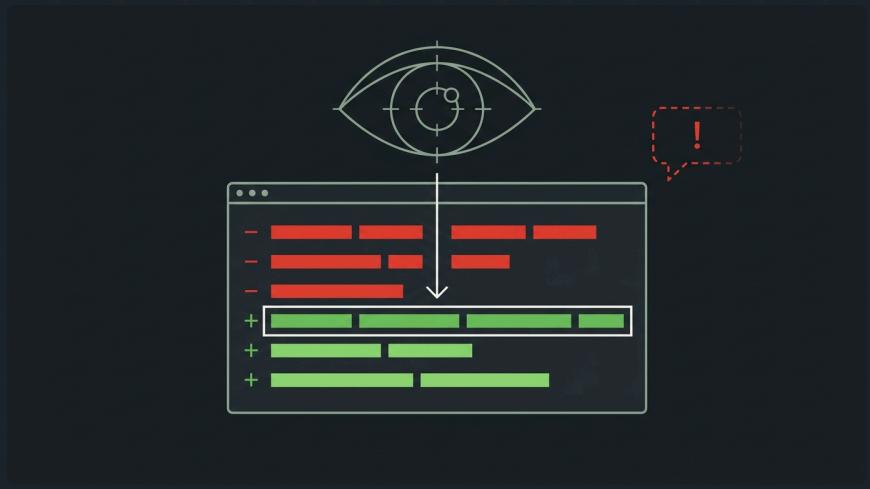


New Game+ : le final humain

Les leçons, les angles morts, le speedrun

La confiance aveugle : le piège côté humain

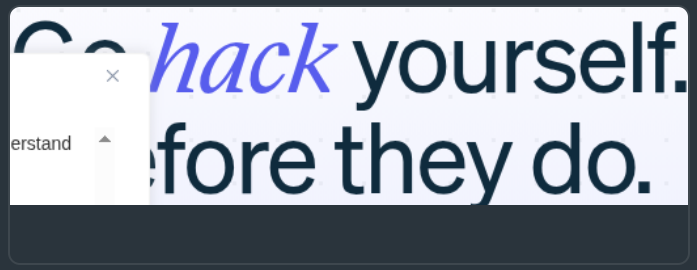
- « Ça a l'air confiant, donc c'est vrai » : convaincante même fausse, le ton assertif est **par conception**
- **Exige ses preuves** : demande à l'IA ce qui appuie sa réponse (sources, diffs, commandes)
- **Don't trust, verify** : les preuves sous les yeux, l'humain tranche



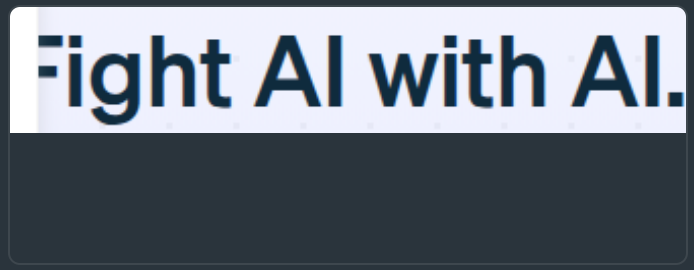
Même pitch depuis Mimikatz

- Hier, la démo qui vendait : **« on détecte Mimikatz »**
- Aujourd'hui, le slogan reste le même, l'objet change : **« l'IA hacker fait tout »**
- **Sans transparence pis contrôle : pas une bonne solution à long terme**

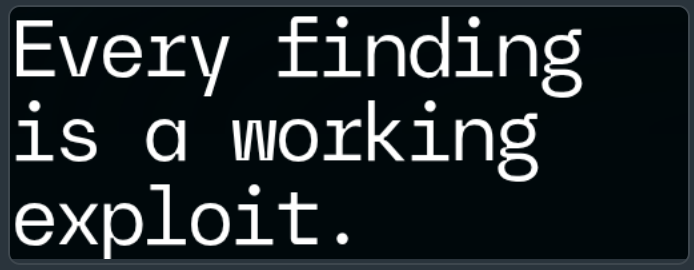
Trois slogans, aucune balle d'argent



Horizon3.ai



Horizon3.ai



XBOW

L'agent n'est pas une balle d'argent

- La sécurité à 100 % n'existe pas : **l'IA qui fait tout, non plus**
- Rien de magique : des **workflows** appris, servis à chaque mandat
- Un agent **rassemble**, un autre attaque en **revue adverse**
- Bien réglé : **~90 %** du chemin sur le rapport pis les tests
- **L'humain dans la boucle** : c'est lui qui tranche
- **Je crois qu'il faut l'adopter**, forces pis limites connues

Répare le système, pas le symptôme

- Recorriger la sortie à la main : le voyant se rallume au prochain run
- La règle, le skill ou le harnais : **toute une classe d'erreurs disparaît**



Le coût caché

- Le temps de prompt engineering et de débogage d'agents
- La maintenance : les outils d'IA changent sous vos pieds
- Le coût cognitif de la supervision constante
- La surprise : tu ne sais pas ce qui a mal tourné **tant que tu ne le demandes pas**

Ça vaut la peine, ou pas

Ça vaut la peine

- Tâches répétitives, vérifiables, à fort volume
- Le rapport : je fais **plus confiance**, chaque constat arrive avec sa preuve, je valide vite

Ça n'en vaut pas encore la peine

- Jugement, créativité, contexte client unique
- Ce qui ne se vérifie pas sans doute possible

Les leçons : 1/2

1. Commence par ce qui se vérifie **sans doute possible**
2. Pas de balle d'argent : le **système** bien réglé fait **~90 %** du chemin
3. Ça replante : **répare le système**, pas le symptôme

Les leçons : 2/2

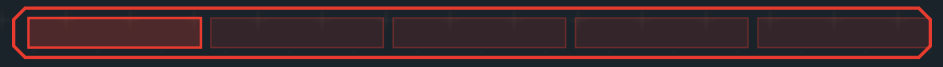
4. Vite nulle part ou vite dans le mur : **retire l'ambiguïté**
5. Celui qui écrit **ne se valide pas** : un 2e agent attaque, un autre modèle recommandé
6. Le « dans ta tête » ne se délègue pas : l'IA y empile les suppositions
7. L'IA accélère, **la pensée ne se délègue pas**

Mes angles morts : ce qui a mal tourné

- L'échec **silencieux** : il dit « fait » sans l'avoir fait
- Garde-fou : **revérifier que le travail est fait**, pas le croire
- Appris trop tard : retirer l'ambiguïté dès le brief, ça a coûté des heures de pistes fausses

Speedrun № 1 : les hallucinations → la revue adverse

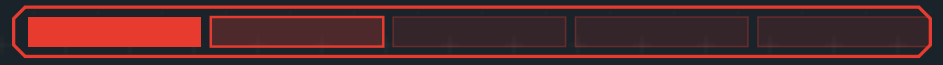
BOSS 1 / 5



- Celui qui écrit **ne se valide pas**
- **Le même modèle suffit** : l'œil vient de l'extérieur · **un autre modèle fait mieux** : il voit ce que l'autre répète
- L'exemple : **mes clés Git ont fui**, trouvées par l'agent qui teste sans arrêt

Speedrun № 2 : le Bottleneck → tes skills, ta voix

BOSS 2 / 5



- Enseigné une fois, le skill se **reproduit à chaque mandat**
- Ce que tu ne dis pas, l'invocation le **suppose**
- Fais-lui **poser ses questions avant d'agir**

Speedrun № 3 : le chaos → l'agentbox, sa machine

BOSS 3 / 5



- Sans ses outils, l'invocation en **improvise**
- Container **jetable et durci** : elle installe ou crée les siens

Speedrun № 4 : l'opacité → lui donner des yeux

BOSS 4 / 5



- Le trafic du modèle **journalisé** : rien ne passe en secret
- « C'est fait » **se vérifie** : la preuve sous les yeux
- **Navigateur** : Playwright ou Browser Use · **interception** : Interceptor
- **Surf discret** : Camoufox · **modèle de vision** pour les images

Speedrun № 5 : la collaboration → un seul plan

BOSS 5 / 5



- **itsaplan** : le plan partagé, les fichiers non
- Le workflow appris **sert tous les mandats suivants**
- L'exemple : **le QA du rapport**, trop grand pour une fenêtre de contexte

Les liens du talk : pour repartir

- **grill-me** (Matt Pocock) : github.com/mattpocock/skills · le contradicteur en skill
- **kit YesWeHack** : github.com/yeswehack/claude-kit · les skills de rédaction de rapport
- **La voix** : Handy · WisprFlow · la dictée, locale ou IA
- **Orca** : onorca.dev · le cockpit de la flotte
- **itsaplan** : github.com/croffasia/itsaplan · un seul plan pour le swarm
- **agentbox** : github.com/ViperBlackSkull/agentbox · containers jetables pis durcis
- **llmproxy** : github.com/ViperBlackSkull/llmproxy · le trafic du modèle, journalisé
- **guardian** : github.com/ViperBlackSkull/guardian-poc · le filtre prompt-injection

Questions?

Simon « Viper » Nolet

YouTube : @hacktiveeducation · démos IA et cyber, sans hype
Me rejoindre : viperblackskull.github.io · tous mes canaux au même endroit
Diapos : github.com/ViperBlackSkull/Presentations

Merci · GG · HackFest 2026